

Laboratorio evolutivo 05

Seguridad y gobernanza de Digital Café Luna en AWS

Cloud Computing Posgrado · Semana 5 · Cuenta AWS estándar

Duración	Modalidad	Entorno	Carácter
80–90 min	Equipos de 4	Cuenta AWS estándar	Formativo; con evidencia

1. Propósito y resultado

Demostrar que reachability no implica authorization: una misma instancia, con el mismo IAM Role y la misma conectividad, puede obtener un objeto y recibir AccessDenied sobre otro cuando la policy cambia el alcance de la autorización.

Al finalizar, el equipo habrá usado credenciales temporales entregadas mediante un IAM Role para EC2, habrá demostrado un GetObject permitido, dos denegaciones controladas por Action/Resource, habrá verificado cifrado SSE-S3 y habrá localizado un management event pertinente en CloudTrail Event history.

Objetivos de aprendizaje

- Distinguir reachability, identity y authorization durante una operación AWS.
- Relacionar Action y Resource dentro de una policy de least privilege con un comportamiento observable.
- Explicar por qué un IAM Role en EC2 evita configurar access keys estáticas en el workload.
- Separar cifrado at rest de autorización: proteger datos y decidir quién puede leerlos son controles distintos.
- Usar CloudTrail Event history para atribuir una acción de administración a un principal, un momento y un contexto.

Alcance de esta iteración

S05 implementa IAM Role, instance profile, policy acotada, S3 privado, SSE-S3 y evidencia de CloudTrail. No se profundiza en IAM users, access keys, KMS avanzado, Secrets Manager hands-on, Organizations/SCP, GuardDuty, Security Hub, WAF, CloudWatch ni IaC. La conectividad pública de Subnet A es temporal y existe solo para acceder a EC2 y permitir llamadas a servicios AWS; networking profundo ya fue tratado en S04.

Ruta de la sesión

Tiempo	Bloque	Salida
0–10 min	Preflight + baseline	Entorno limpio y nombres definidos
10–22 min	S3 + IAM	Bucket, objetos, role y policy mínima
22–35 min	Conectividad + EC2	Workload temporal con instance profile
35–55 min	Pruebas de autorización	PASS + AccessDenied por Resource/Action
55–65 min	Cifrado + CloudTrail	SSE-S3 y management event
65–75 min	Troubleshooting + evidencias	Causa explicada con evidencia
75–90 min	Cleanup + cierre	Baseline S01 restaurado

Arquitectura objetivo

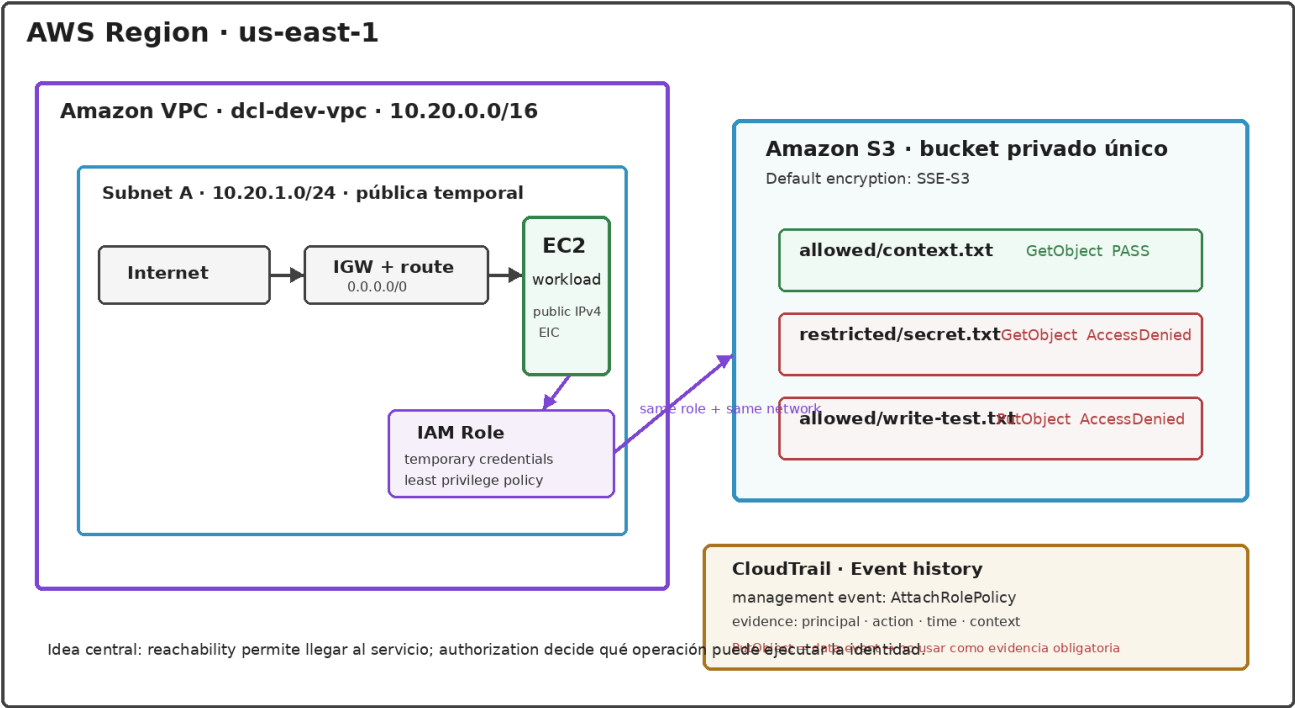


Figura 1. La conectividad permanece constante; cambian Action y Resource dentro de la autorización.

La EC2 temporal usa un IAM Role a través de su instance profile. AWS CLI obtiene credenciales temporales automáticamente desde la instancia. La policy solo permite s3:GetObject sobre allowed/*. El mismo workload prueba un objeto fuera de ese Resource y una acción PutObject no concedida. El bucket permanece privado y con SSE-S3; CloudTrail Event history se usa para un management event como AttachRolePolicy, no para PutObject.

2. Estándar del laboratorio

Región y baseline

Trabajen en us-east-1. No reconstruyan el baseline ni reutilicen componentes temporales de S02–S04. La única infraestructura persistente autorizada al entrar al lab es la VPC y las dos subnets creadas en S01.

Recurso	Nombre / valor
VPC	dcl-dev-vpc · 10.20.0.0/16
Subnet A	dcl-dev-subnet-a · 10.20.1.0/24
Subnet B	dcl-dev-subnet-b · 10.20.2.0/24
Distribución	Dos Availability Zones distintas

Nomenclatura S05

Recurso	Nombre
Bucket S3	dcl-s05-teamXX-<account-id>
IAM Role / instance profile	dcl-dev-role-s05
Customer managed policy	dcl-dev-policy-s3-read-allowed-s05
EC2	dcl-dev-ec2-s05

Recurso	Nombre
Security Group	dcl-dev-sg-ec2-s05
Internet Gateway	dcl-dev-igw-s05
Route table temporal	dcl-dev-rt-public-a-s05

Apliquen `dcl:project=digital-cafe-luna`, `dcl:environment=dev`, `dcl:owner-team=team-XX` y `dcl:managed-by=console` cuando el servicio admita tags. El nombre del bucket debe ser globalmente único; usar el account ID evita colisiones entre equipos/cuentas.

3. Preflight técnico

Qué hacemos: confirmar el baseline, los permisos normales de la cuenta y las condiciones que hacen inequívoca la prueba de autorización.

Por qué: si sobreviven recursos de labs anteriores, existe una bucket policy ajena o se usan credenciales manuales, un `AccessDenied` puede tener otra causa y la evidencia deja de demostrar la intención de S05.

1. Inicien sesión en la cuenta AWS y seleccionen `us-east-1`.
2. Confirman `dcl-dev-vpc` y las dos subnets con sus CIDR exactos y AZ distintas.
3. Verifiquen que no existan EC2, IGW, route tables o Security Groups temporales de S02–S04 que condicionen la prueba.
4. Confirman permisos normales para S3, IAM, EC2, VPC y CloudTrail Event history. Si una SCP, `permissions boundary` u otra política externa bloquea el lab, registren el control; no amplíen permisos a ciegas.
5. No creen access keys ni ejecuten `aws configure` en la EC2. El workload debe obtener credenciales desde su IAM Role.
6. Antes de las pruebas, el bucket no debe tener una bucket policy creada por otro ejercicio y los dos objetos de prueba deben existir con nombres exactos.

Validación: el baseline coincide con S01; el entorno temporal está limpio; el equipo puede explicar que la prueba comparará la misma red y la misma identidad, modificando únicamente `Action/Resource`.

Paso 1 — Crear el bucket y los dos objetos

Qué hacemos: crear un bucket S3 privado y dos objetos existentes bajo prefijos distintos.

Por qué: el objeto `restricted` debe existir antes del `AccessDenied`; de lo contrario, un error de nombre o un recurso inexistente podría confundirse con autorización.

7. En S3, creen `dcl-s05-teamXX-<account-id>` en `us-east-1`.
8. Mantengan `Block Public Access` habilitado. No creen bucket policy para este lab.
9. Mantengan `default encryption` en `SSE-S3`. No utilicen una `customer managed KMS key`.
10. Suban `allowed/context.txt` con un texto breve como “Digital Café Luna — lectura autorizada”.
11. Suban `restricted/secret.txt` con un texto breve diferente, por ejemplo “Digital Café Luna — recurso restringido”.
12. No habiliten `Versioning`; S03 ya cubrió ese comportamiento.

Validación: ambos objetos existen en el mismo bucket; el bucket es privado; `Default encryption` muestra `SSE-S3`.

Evidencia: registren el nombre del bucket y la vista donde se observan ambos keys. Esta captura apoya la prueba, pero no sustituye la evidencia de autorización efectiva.

Paso 2 — Crear policy, role e instance profile

Qué hacemos: crear una policy mínima y asociarla a un IAM Role para EC2.

Por qué: el workload necesita una identidad con permisos precisos. El IAM console crea el instance profile de EC2 con el mismo nombre del role; ese profile es el contenedor que entrega el role a la instancia.

Creen primero la `customer managed policy` `dcl-dev-policy-s3-read-allowed-s05` usando el JSON siguiente. Sustituyan `BUCKET_NAME` por el nombre real; no agreguen `s3:ListBucket`, `s3:*` ni `Resource: "*"`.

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "ReadAllowedPrefixOnly",
      "Effect": "Allow",
      "Action": "s3:GetObject",
      "Resource": "arn:aws:s3:::BUCKET_NAME/allowed/*"
    }
  ]
}
```

13. Creen dcl-dev-role-s05 con trusted entity = AWS service y use case = EC2.
14. Adjunte dcl-dev-policy-s3-read-allowed-s05 al role. Hagan esta asociación explícitamente: generará un management event AttachRolePolicy útil para CloudTrail.
15. Confirмен que el role no tenga otras políticas que otorguen acceso S3 y que el instance profile dcl-dev-role-s05 esté disponible para EC2.

Validación: el role tiene una única policy funcional para el lab y esa policy concede solo s3:GetObject sobre arn:aws:s3:::<bucket>/allowed/*.

4. Workload temporal y conectividad mínima

Paso 3 — Hacer pública temporalmente la Subnet A

Qué hacemos: recrear solo el camino mínimo ya conocido desde S04 para acceder a una EC2 temporal y permitirle llegar a endpoints públicos de AWS.

Por qué: Subnet A no conserva el IGW ni la route table de S04. La conectividad es prerequisite operativo; no forma parte de la variable de autorización que vamos a cambiar.

16. Creen dcl-dev-igw-s05 y adjúntenlo a dcl-dev-vpc.
17. Creen dcl-dev-rt-public-a-s05 y agreguen 0.0.0.0/0 → dcl-dev-igw-s05.
18. Asocien únicamente dcl-dev-subnet-a a esa route table. No modifiquen Subnet B.
19. Creen dcl-dev-sg-ec2-s05. Inbound: SSH TCP/22 únicamente desde el AWS-managed prefix list com.amazonaws.us-east-1.ec2-instance-connect. Outbound: default.

Validación: Subnet A tiene temporalmente local + 0.0.0.0/0 → IGW; Subnet B permanece intacta; el SG no abre SSH a 0.0.0.0/0.

Paso 4 — Lanzar la EC2 con el IAM Role

Qué hacemos: lanzar una sola EC2 pequeña con public IPv4 y el instance profile dcl-dev-role-s05.

Por qué: todas las pruebas deben ejecutarse desde la misma identidad y la misma red para que la diferencia observable dependa de la policy.

20. AMI: Amazon Linux 2023 estándar; instance type: t3.micro o el tipo pequeño equivalente definido por el curso.
21. Subnet = dcl-dev-subnet-a; Auto-assign public IP = Enable; Security Group = dcl-dev-sg-ec2-s05.
22. IAM instance profile = dcl-dev-role-s05. Procedan sin key pair; EC2 Instance Connect será el método de acceso.
23. Root volume mínimo y Delete on termination = Yes. No agreguen discos ni software adicional.

Validación: EC2 está running, tiene public IPv4, muestra IAM Role dcl-dev-role-s05 y pasa status checks.

Paso 5 — Entrar con EC2 Instance Connect

Qué hacemos: abrir una terminal en dcl-dev-ec2-s05 desde EC2 > Connect > EC2 Instance Connect > Connect using a Public IP.

Por qué: Amazon Linux 2023 incluye AWS CLI v2 y EC2 Instance Connect. No necesitamos key pair ni access keys AWS configuradas en el sistema operativo.

```
aws --version
aws configure list
```

Validación: la terminal está disponible. No existe una credencial persistente creada manualmente para el lab; AWS CLI puede resolver credenciales mediante el role/instance metadata.

5. Prueba central — misma identidad, distinto alcance

Definan el bucket una sola vez y no cambien de terminal, role ni red entre pruebas.

```
export BUCKET="dcl-s05-teamXX-<account-id>"
echo "Bucket de prueba: ${BUCKET}"
```

Prueba 1 — Identidad del workload

Qué hacemos: consultar la identidad efectiva usada por AWS CLI.

Por qué: antes de interpretar un Allow o Deny hay que demostrar quién ejecuta la operación.

```
aws sts get-caller-identity --query '{Account:Account,Arn:Arn}' --output table
```

Validación: el ARN contiene assumed-role/dcl-dev-role-s05/... y corresponde a una sesión del role asociado a la EC2, no a un IAM user ni a access keys configuradas manualmente.

Evidencia: captura o salida del comando donde el ARN del assumed role sea legible.

Prueba 2 — Resource permitido: PASS

Qué hacemos: ejecutar exactamente la Action concedida sobre un Resource que coincide con allowed/*.

Por qué: esta prueba establece que reachability, DNS, credenciales y la Action s3:GetObject funcionan desde el workload.

```
aws s3api get-object \
--bucket "$BUCKET" \
--key allowed/context.txt \
/tmp/context.txt
cat /tmp/context.txt
```

Validación: GetObject termina sin error y el contenido esperado aparece en terminal. Registren PASS.

Evidencia: salida del comando y contenido recuperado.

Prueba 3 — Mismas Action/red/identidad, Resource fuera de alcance

Qué hacemos: repetir s3:GetObject sobre restricted/secret.txt.

Por qué: la Action sigue siendo GetObject y la conectividad no cambia; únicamente el Resource deja de coincidir con arn:aws:s3:::<bucket>/allowed/*.

```
aws s3api get-object \
--bucket "$BUCKET" \
--key restricted/secret.txt \
/tmp/secret.txt
```

Validación: el resultado es AccessDenied. El objeto ya fue confirmado como existente y la prueba anterior demuestra que la EC2 sí alcanza S3; la diferencia observable corresponde al alcance de Resource.

Evidencia: AccessDenied legible junto al nombre exacto del key probado.

Prueba 4 — Resource permitido, Action no concedida

Qué hacemos: intentar PutObject dentro de allowed/ sin modificar la policy.

Por qué: ahora el Resource coincide con el prefijo permitido, pero la Action s3:PutObject no está concedida.

```
printf 'write test\n' > /tmp/write-test.txt
aws s3api put-object \
--bucket "$BUCKET" \
--key allowed/write-test.txt \
--body /tmp/write-test.txt
```

Validación: el resultado es AccessDenied. Si el comando llega a crear el objeto, detengan la prueba: existe otro permiso que amplía el role y el lab no está demostrando least privilege de forma aislada.

Evidencia: AccessDenied de PutObject sobre allowed/write-test.txt.

6. Cifrado y trazabilidad

Paso 6 — Verificar cifrado at rest

Qué hacemos: revisar S3 > bucket > Properties > Default encryption y, en uno de los objetos, sus propiedades de server-side encryption.

Por qué: cifrado y autorización resuelven problemas distintos. SSE-S3 protege el dato at rest; la policy decide qué identidad puede ejecutar qué acción sobre qué recurso.

Validación: Default encryption = SSE-S3 / Amazon S3 managed keys. No se necesita una customer managed KMS key para cumplir este objetivo.

Evidencia: captura del estado de encryption del bucket u objeto. No la presenten como evidencia de autorización.

Paso 7 — Localizar un management event en CloudTrail Event history

Qué hacemos: abrir CloudTrail > Event history en us-east-1 y buscar el management event AttachRolePolicy generado al asociar la policy al role.

Por qué: Event history permite atribuir acciones de administración sin crear un trail dedicado. El evento debe responder quién, qué, cuándo y sobre qué contexto se actuó.

24. Mantengan us-east-1 seleccionada. Event history es regional y muestra los últimos 90 días de management events.
25. Filtrén Event name = AttachRolePolicy. Si todavía no aparece, esperen unos minutos y refresquen; CloudTrail tiene entrega eventual.
26. Elijan el evento cuyo requestParameters.roleName sea dcl-dev-role-s05 y cuya policyArn corresponda a dcl-dev-policy-s3-read-allowed-s05.
27. En Event record identifiquen userIdentity/principal, eventTime, eventName/eventSource, requestParameters y el contexto del recurso.

Validación: el equipo puede señalar principal, acción, momento y role/policy afectados en un evento real del lab.

Evidencia: detalle de AttachRolePolicy en Event history con campos suficientes para atribuir la acción.

OJO TÉCNICO: PutObject, GetObject y DeleteObject sobre objetos S3 son data events. CloudTrail Event history muestra management events y no debe usarse PutObject como evidencia obligatoria aquí. No creen un trail ni habiliten data events solo para completar este lab.

Lectura comparada

Prueba	Identity	Action	Resource	Resultado	Qué demuestra
Get allowed	mismo role	GetObject	allowed/context.txt	PASS	Action + Resource autorizados
Get restricted	mismo role	GetObject	restricted/secret.txt	AccessDenied	Resource fuera de alcance
Put allowed	mismo role	PutObject	allowed/write-test.txt	AccessDenied	Action no concedida

7. Troubleshooting basado en evidencia

Pregunta guía

¿Qué evidencia permite afirmar que este AccessDenied es una decisión de autorización y no un problema de red?

La respuesta esperada conecta varias señales: GetObject sobre allowed/context.txt funciona desde la misma EC2; restricted/secret.txt existe; get-caller-identity muestra el mismo role; el error ocurre al cambiar Resource o Action; la policy visible coincide con ese límite. No hace falta abrir permisos para diagnosticar.

Síntoma	Qué revisar primero	Evidencia útil
Could not connect to endpoint / timeout	Reachability, DNS, route, salida	Prueba de endpoint + route table + public IPv4
Unable to locate credentials	Identity / instance profile	IAM Role en EC2 + get-caller-identity
NoSuchKey	Nombre / existencia del recurso	Objeto visible con key exacto
AccessDenied en Get restricted	Resource / authorization	Get allowed PASS + policy limitada a allowed/*
AccessDenied en Put allowed	Action / authorization	Get allowed PASS + policy sin s3:PutObject
Get restricted devuelve PASS	Permiso más amplio no previsto	Policies del role / boundary / resource policy

OJO TÉCNICO: No “resuelvan” un AccessDenied agregando AmazonS3FullAccess, s3:* o Resource: """. Si una prueba falla de forma inesperada, identifiquen primero identity, Action, Resource y cualquier policy adicional. El troubleshooting también es parte de la evidencia.

8. Evidencias mínimas y criterios de aceptación

- get-caller-identity mostrando assumed-role/dcl-dev-role-s05.
- GetObject de allowed/context.txt con resultado PASS y contenido visible.
- GetObject de restricted/secret.txt con AccessDenied.
- PutObject sobre allowed/write-test.txt con AccessDenied.
- SSE-S3/default encryption verificado sin confundir cifrado con autorización.
- AttachRolePolicy —u otro management event equivalente y pertinente— visible en CloudTrail Event history, con principal, acción, tiempo y contexto.
- Cleanup final donde solo permanece el baseline S01.

Regla de evidencia

Una captura del role o de la policy creada no sustituye evidencia de autorización efectiva. El criterio de aceptación es el comportamiento observado: PASS donde corresponde y AccessDenied controlado donde la policy no concede Action/Resource.

Checkpoint conceptual

Al cerrar S05, el equipo debe poder explicar esta cadena sin mezclar controles: reachability permite que el workload llegue al endpoint; el role define la identidad; la policy limita Action y Resource; encryption protege datos at rest; CloudTrail permite atribuir acciones de administración.

9. Costos, conservación y cleanup

Cost awareness

Mantengan S05 pequeño y temporal. No se crea NAT Gateway, customer managed KMS key, Secrets Manager ni trail dedicado. El costo principal durante la sesión proviene de la EC2, su root EBS y la public IPv4; S3 genera almacenamiento/requests mínimos y SSE-S3 no añade costo de cifrado. CloudTrail Event history puede consultarse sin crear infraestructura adicional.

Recurso	Tratamiento
EC2 + root EBS + public IPv4	Temporal; terminar al cerrar
S3 bucket + dos objetos	Temporal; vaciar y eliminar
IAM role / instance profile / policy	Temporal; eliminar después de terminar EC2
IGW + route table + SG	Temporal; eliminar y restaurar Subnet A al baseline
CloudTrail Event history	No crear trail; no hay recurso del lab que conservar

CONSERVAR COMO BASELINE

- dcl-dev-vpc · 10.20.0.0/16.
- dcl-dev-subnet-a · 10.20.1.0/24 y su Availability Zone.
- dcl-dev-subnet-b · 10.20.2.0/24 y su Availability Zone.
- Naming/tags del proyecto y evidencias/checkpoint del equipo.

ELIMINAR — cleanup obligatorio

28. Terminen dcl-dev-ec2-s05 y verifiquen que su root EBS no quede huérfano.
29. Eliminen dcl-dev-sg-ec2-s05 cuando ya no tenga dependencias.
30. Desasocien dcl-dev-rt-public-a-s05 de Subnet A; Subnet A vuelve a la main route table. Eliminen la route table temporal.
31. Desadjunte y eliminen dcl-dev-igw-s05.
32. Vacíen el bucket S3 y elimínenlo. Si Versioning se habilitó accidentalmente, eliminen todas las versiones y delete markers antes de borrar el bucket.
33. Desadjunte dcl-dev-policy-s3-read-allowed-s05 del role y eliminen la customer managed policy.
34. Eliminen dcl-dev-role-s05. Si se creó desde IAM console, verifiquen que el instance profile del mismo nombre también haya sido eliminado.
35. Eliminen cualquier objeto de troubleshooting o recurso accidental que no pertenezca al baseline S01.

Validación de cleanup: no quedan EC2, public IPv4, Security Group, route table, IGW, bucket/objetos, policy, instance profile ni IAM Role de S05. Permanecen únicamente VPC, dos subnets y el checkpoint.

10. Cierre técnico

- Reachability responde “¿puedo llegar?”; authorization responde “¿puedo ejecutar esta Action sobre este Resource?”.
- Un IAM Role entrega credenciales temporales al workload sin almacenar access keys estáticas en la instancia.
- Least privilege se demuestra mejor con comportamiento: un permiso preciso debe producir PASS y Deny reproducibles.
- Encryption at rest no sustituye IAM; CloudTrail no sustituye controles preventivos. Cada mecanismo responde a una pregunta distinta.

Fuentes oficiales

- [AWS — Use temporary credentials with AWS resources](#)
- [AWS — Use instance profiles](#)
- [AWS — Prerequisites for EC2 Instance Connect](#)
- [AWS — Configuring default encryption for Amazon S3](#)
- [AWS — Working with CloudTrail event history](#)

- [AWS — Amazon S3 CloudTrail events](#)